

MODELO DE ENCUESTA INTEGRAL CVSS 4.0

Diagnóstico de Madurez en Gestión de Vulnerabilidades con Aplicación Territorial en España

Kit de Evaluación Organizacional • Edición 2025-2026

"Dime cómo puntúas tus vulnerabilidades y te diré cómo gestionas tu riesgo. O si acaso lo gestionas."

— Aforismo de sala de crisis, atribuido a ningún CISO satisfecho

INSTRUCCIONES GENERALES

Destinatarios: Responsables de Seguridad de la Información (CISO, RSSI, Responsable ENS), Directores de TI/OT, Responsables de Cumplimiento, Gestores de Riesgo, Responsables de Continuidad de Negocio y cualquier profesional con responsabilidad directa o indirecta en la gestión de vulnerabilidades de ciberseguridad.

Tiempo estimado de cumplimentación: 35-50 minutos

Escala de respuesta (salvo indicación contraria):

- Las preguntas cerradas emplean escalas de Likert 1-5, opciones de selección múltiple o respuestas dicotómicas (Sí/No/En proceso).
- Las preguntas abiertas invitan a una reflexión libre y constructiva.
- Cuando se indica **[Múltiple]**, pueden seleccionarse todas las opciones que correspondan.
- Cuando se indica **[Única]**, seleccione exclusivamente una opción.

Anonimato y confidencialidad: Las respuestas se tratarán de forma agregada. Ninguna respuesta individual será identificable en el informe final.

Secciones:

1. Perfil organizacional
2. Conocimiento y adopción de CVSS 4.0
3. Métricas Base: uso y comprensión
4. Métricas Threat: inteligencia aplicada
5. Métricas Environmental: el contexto que importa
6. Métricas Supplemental: seguridad, resiliencia y automatización
7. Integración con marcos normativos (ENS, NIS2, DORA, CRA)
8. Infraestructura tecnológica y herramientas
9. Gobierno, cultura y capacitación
10. Perspectiva estratégica y tendencias emergentes

SECCIÓN 1 — PERFIL ORGANIZACIONAL

Antes de entrar en materia, conviene conocer el ecosistema desde el que habla.

P1.1 — Tipo de organización [Única]

- ☐ Administración General del Estado (AGE)
- ☐ Comunidad Autónoma (Gobierno autonómico y organismos dependientes)
- ☐ Entidad Local (Ayuntamiento, Diputación, Cabildo, Consell)
- ☐ Universidad pública
- ☐ Hospital / Centro sanitario público
- ☐ Empresa pública o sociedad mercantil de capital público
- ☐ Empresa privada del sector financiero (banca, seguros, infraestructura de mercados)
- ☐ Empresa privada del sector energético o utilities
- ☐ Empresa privada del sector transporte e infraestructuras
- ☐ Empresa privada del sector telecomunicaciones
- ☐ Empresa privada de otro sector regulado (especifique): ____
- ☐ Empresa privada no regulada
- ☐ Proveedor de servicios gestionados de seguridad (MSSP)
- ☐ Consultoría o integrador de ciberseguridad
- ☐ Otro (especifique): ____

P1.2 — Tamaño organizacional por número de empleados [Única]

- ☐ Menos de 50 empleados
- ☐ 50–249 empleados
- ☐ 250–999 empleados
- ☐ 1.000–4.999 empleados
- ☐ 5.000–19.999 empleados
- ☐ 20.000 o más empleados

P1.3 — Ámbito territorial de operaciones [Múltiple]

- ☐ Local (un municipio o comarca)
- ☐ Provincial
- ☐ Regional / Autonómico
- ☐ Nacional (presencia en múltiples CCAA)
- ☐ Europeo (operaciones en la UE)
- ☐ Global (presencia fuera de la UE)

P1.4 — Comunidad Autónoma donde se ubica la sede principal [Única]

- ☐ Andalucía · ☐ Aragón · ☐ Asturias · ☐ Islas Baleares · ☐ Canarias
- ☐ Cantabria · ☐ Castilla-La Mancha · ☐ Castilla y León · ☐ Cataluña
- ☐ Extremadura · ☐ Galicia · ☐ La Rioja · ☐ Comunidad de Madrid
- ☐ Región de Murcia · ☐ Comunidad Foral de Navarra · ☐ País Vasco
- ☐ Comunidad Valenciana · ☐ Ceuta · ☐ Melilla

P1.5 — Rol del encuestado en la organización [Única]

- ☐ CISO / Responsable de Seguridad de la Información (RSI/RSSI)
- ☐ Responsable ENS / DPO / Compliance Officer
- ☐ Director/a de Tecnología (CTO / CIO)
- ☐ Responsable de Operaciones de Seguridad (SOC Manager)
- ☐ Analista de Vulnerabilidades / Threat Intelligence
- ☐ Arquitecto/a de Seguridad
- ☐ Responsable de Continuidad de Negocio / Resiliencia
- ☐ Auditor/a interno/a o externo/a
- ☐ Directivo/a con responsabilidad general (CEO, COO, CFO)
- ☐ Otro (especifique): _____

P1.6 — Años de experiencia profesional en ciberseguridad [Única]

- ☐ Menos de 2 años
- ☐ 2–5 años
- ☐ 6–10 años
- ☐ 11–15 años
- ☐ Más de 15 años

P1.7 — ¿Su organización está sujeta al Esquema Nacional de Seguridad (ENS)? [Única]

- ☐ Sí, de forma obligatoria y estamos certificados
- ☐ Sí, de forma obligatoria y estamos en proceso de certificación
- ☐ Sí, de forma obligatoria pero aún no hemos iniciado el proceso formal
- ☐ No estamos obligados, pero lo adoptamos voluntariamente como referencia
- ☐ No estamos obligados ni lo aplicamos
- ☐ Desconozco si estamos obligados (respuesta que, sin juzgar, invita a la reflexión)

P1.8 — Categoría ENS del sistema de información más crítico de su organización [Única]

- ☐ ALTO
- ☐ MEDIO
- ☐ BAJO
- ☐ No hemos realizado aún la categorización ENS
- ☐ No aplica

SECCIÓN 2 — CONOCIMIENTO Y ADOPCIÓN DE CVSS 4.0

*Porque hay estándares que se mencionan en las reuniones y estándares que se aplican en las trincheras.
Distinción importante.*

P2.1 — ¿Conoce el estándar CVSS (Common Vulnerability Scoring System)? [Única]

- ☐ Sí, lo conozco en profundidad y lo aplico activamente
- ☐ Sí, tengo un conocimiento sólido aunque no lo aplico directamente
- ☐ Lo conozco a nivel general pero no en detalle técnico
- ☐ He oído hablar de él pero no tengo conocimiento sustancial
- ☐ No lo conozco

P2.2 — ¿Conoce específicamente CVSS versión 4.0, publicada en noviembre de 2023? [Única]

- ☐ Sí, conozco sus novedades estructurales (métricas Threat, Supplemental, nuevos valores UI, AT)
- ☐ Sí, sé que existe pero no he profundizado en los cambios respecto a v3.x
- ☐ No sabía que existía una versión 4.0
- ☐ Pensaba que la versión más reciente era la 3.1

P2.3 — ¿Qué versión de CVSS utiliza actualmente su organización como referencia primaria? [Única]

- ☐ CVSS 4.0 exclusivamente
- ☐ Combinación de CVSS 4.0 y CVSS 3.1 (transición en curso)
- ☐ CVSS 3.1 exclusivamente
- ☐ CVSS 3.0 o anterior
- ☐ Usamos el CVSS que nos proporciona la herramienta sin verificar la versión
- ☐ No utilizamos CVSS de forma sistemática
- ☐ No utilizamos ningún sistema formal de puntuación de vulnerabilidades

P2.4 — ¿Cuál es la principal razón para no haber migrado aún a CVSS 4.0? [Única — solo si aplica]

- ☐ Nuestras herramientas actuales no soportan CVSS 4.0
- ☐ Falta de tiempo y recursos para actualizar procesos y formación
- ☐ Adoptamos lo que publica el NVD/INCIBE-CERT sin ajustes propios
- ☐ La cobertura de CVEs con puntuación v4 es aún muy limitada ($\approx 2,4\%$ del total)
- ☐ Esperamos a que la versión 4.0 se consolide más antes de invertir en el cambio
- ☐ No percibimos diferencia práctica relevante respecto a v3.1
- ☐ Otro (especifique): _____
- ☐ No aplica (ya usamos CVSS 4.0)

P2.5 — En su organización, ¿quién es responsable de asignar o validar puntuaciones CVSS? [Múltiple]

- ☐ El equipo interno de seguridad / SOC
- ☐ Se adopta directamente la puntuación publicada por el fabricante (PSIRT)
- ☐ Se adopta la puntuación del NVD (NIST)
- ☐ Se adopta la puntuación de INCIBE-CERT
- ☐ Un proveedor de servicios gestionados (MSSP) externo
- ☐ Una herramienta automatizada de gestión de vulnerabilidades
- ☐ Nadie en particular / no existe un proceso definido
- ☐ Otro (especifique): _____

P2.6 — ¿Cada cuánto tiempo revisa/actualiza las puntuaciones CVSS de las vulnerabilidades pendientes de remediación? [Única]

- ☐ En tiempo real o cuasi real (herramientas automatizadas con feeds de inteligencia)
- ☐ Diariamente
- ☐ Semanalmente
- ☐ Mensualmente
- ☐ Solo cuando se detecta una nueva alerta o incidente
- ☐ No realizamos actualizaciones de puntuaciones; las asignadas inicialmente son definitivas
- ☐ No tenemos un proceso de gestión de vulnerabilidades formalizado

P2.7 — Valore su nivel de acuerdo con la siguiente afirmación: "En nuestra organización, el CVSS Base Score publicado por el proveedor se utiliza como la puntuación definitiva para priorizar la remediación, sin ajustes adicionales."

Escala	Selección
1 — Totalmente en desacuerdo (siempre enriquecemos con contexto)	☐
2 — En desacuerdo (normalmente ajustamos)	☐
3 — Ni de acuerdo ni en desacuerdo (depende de la vulnerabilidad)	☐
4 — De acuerdo (normalmente usamos el score del proveedor)	☐
5 — Totalmente de acuerdo (siempre usamos el score del proveedor sin ajuste)	☐

SECCIÓN 3 — MÉTRICAS BASE: LO QUE NO CAMBIA (O CASI)

El proveedor asigna el peor escenario razonable. ¿Lo sabemos? ¿Lo reconocemos? ¿Lo cuestionamos?

P3.1 — ¿Conoce los cambios introducidos en las métricas Base de CVSS 4.0 respecto a v3.1? [Múltiple — seleccione las novedades que conoce]

- ☐ La eliminación del parámetro Scope y su sustitución por métricas de impacto en sistemas subsecuentes (SC/SI/SA)
- ☐ La introducción de Attack Requirements (AT) como nueva métrica independiente de Attack Complexity
- ☐ La diferenciación de User Interaction en tres valores: None / Passive / Active
- ☐ La separación entre impacto en el sistema vulnerable (VC/VI/VA) e impacto en sistemas subsecuentes (SC/SI/SA)
- ☐ El cambio en el modelo matemático de equivalence groups (no fórmula lineal clásica)
- ☐ Conozco las novedades pero no en ese nivel de detalle
- ☐ No conozco los cambios específicos de las métricas Base en v4.0

P3.2 — En su organización, ¿se diferencia entre el impacto de una vulnerabilidad en el sistema comprometido (VC/VI/VA) y el impacto en sistemas conectados o subsecuentes (SC/SI/SA)? [Única]

- ☐ Sí, disponemos de un inventario de dependencias entre sistemas que permite evaluar el impacto en cascada
- ☐ Lo hacemos de forma informal para los sistemas más críticos
- ☐ No, evaluamos el impacto de forma global sin distinguir sistemas primarios y subsecuentes
- ☐ No disponemos de un inventario de dependencias suficientemente preciso para hacerlo
- ☐ No aplica a nuestro entorno

P3.3 — ¿Con qué frecuencia la puntuación CVSS Base asignada por el proveedor/NVD/INCIBE refleja con precisión la severidad real en su entorno? [Única]

- ☐ Casi siempre (>80% de los casos): las puntuaciones base son una guía fiable
- ☐ Con frecuencia (50–80%): son un buen punto de partida, aunque con excepciones notables
- ☐ A veces (20–50%): presentan desviaciones frecuentes que debemos corregir
- ☐ Raramente (<20%): las puntuaciones base sobreestiman o subestiman la severidad real con demasiada frecuencia
- ☐ No tenemos datos suficientes para valorarlo

P3.4 — En entornos OT/ICS/SCADA o IoT, ¿dispone de una metodología específica para evaluar el impacto en sistemas de control industrial? [Única]

- ☐ Sí, aplicamos CVSS 4.0 con métricas de impacto en sistemas subsecuentes (SC/SI/SA) específicamente para entornos OT/ICS
- ☐ Usamos una metodología mixta (CVSS + ICS-CERT / ISA/IEC 62443 u otras)
- ☐ Aplicamos CVSS estándar sin adaptación a entornos OT
- ☐ No operamos entornos OT/ICS/SCADA ni IoT industriales
- ☐ Carecemos de metodología específica para OT aunque lo necesitamos

P3.5 [Abierta] — Si tuviera que señalar la mayor disfunción que observa en la práctica diaria del uso de las métricas Base CVSS en su organización o en el sector, ¿cuál sería?

(Campo de texto libre — máx. 400 palabras. No hay respuesta incorrecta; sí hay respuestas que hacen avanzar al sector.)

SECCIÓN 4 — MÉTRICAS THREAT: LA INTELIGENCIA QUE AJUSTA

Exploit Maturity: la diferencia entre "podría pasar" y "está pasando ahora mismo". Matiz capital.

P4.1 — ¿Utiliza su organización las métricas Threat de CVSS para ajustar la priorización de vulnerabilidades? [Única]

- ☐ Sí, aplicamos sistemáticamente la métrica Exploit Maturity (E) a todas las vulnerabilidades relevantes
- ☐ Sí, pero solo a las vulnerabilidades de mayor criticidad (Base Score ≥ 7.0 o ≥ 9.0)
- ☐ Lo hacemos de forma ad hoc cuando hay alertas específicas, no sistemáticamente
- ☐ No utilizamos métricas Threat; trabajamos con la puntuación Base
- ☐ No conocía la existencia de las métricas Threat en CVSS

P4.2 — ¿Cuáles son las fuentes de inteligencia de amenazas que utiliza para determinar la madurez del exploit (Exploit Maturity)? [Múltiple]

- ☐ INCIBE-CERT (alertas de vulnerabilidades y aviso de explotación activa)
- ☐ CCN-CERT (boletines de seguridad, CARMEN, LUCÍA)
- ☐ EUVD (European Union Vulnerability Database — ENISA, desde 2025)
- ☐ CISA KEV (Known Exploited Vulnerabilities Catalog)
- ☐ NVD/NIST (National Vulnerability Database)
- ☐ Exploit-DB / ExploitHub
- ☐ VulnCheck / Nucleus Security / otras plataformas comerciales
- ☐ EPSS (Exploit Prediction Scoring System)
- ☐ Feeds de inteligencia comercial (Mandiant, Recorded Future, CrowdStrike, etc.)
- ☐ Grupos ISAC/ISAO del sector
- ☐ Red Nacional de SOC (RNS-CCN)
- ☐ No utilizamos fuentes formales de inteligencia de amenazas para este fin
- ☐ Otro (especifique): _____

P4.3 — ¿Ha observado que la incorporación de la métrica Exploit Maturity reduce significativamente el volumen de vulnerabilidades a tratar prioritariamente? [Única]

(Nota: La evidencia empírica indica que CVSS 4.0 con métricas Threat reduce en un 65–76% las vulnerabilidades por encima del umbral ≥ 7.0)

- ☐ Sí, y representa una reducción operacionalmente muy significativa en nuestra carga de trabajo
- ☐ Sí, pero la reducción es menor de lo esperado (quizás porque pocas CVEs tienen datos de Threat actualizados)
- ☐ No hemos medido ese efecto de forma cuantitativa
- ☐ No, porque no utilizamos métricas Threat
- ☐ Lo hemos medido y la reducción ha sido marginal en nuestro contexto

P4.4 — En el contexto de la EUVD lanzada por ENISA en abril de 2025, ¿ha integrado esta fuente en sus procesos de gestión de vulnerabilidades? [Única]

- ☐ Sí, la EUVD es nuestra referencia primaria o secundaria para vulnerabilidades con impacto en la UE
- ☐ La hemos evaluado pero aún no la hemos integrado formalmente
- ☐ Conocemos su existencia pero no la utilizamos todavía
- ☐ No conocíamos la EUVD antes de esta pregunta
- ☐ Nuestra política es usar exclusivamente fuentes del fabricante y NVD

P4.5 — Valore el impacto del Cyber Resilience Act (CRA, septiembre 2026) en la disponibilidad de datos de explotación activa para enriquecer las métricas Threat: [Única]

- ☐ Muy alto: la obligatoriedad de notificación a ENISA en 24h transformará la disponibilidad de datos de Exploit Maturity
- ☐ Alto: mejorará significativamente, aunque con resistencias y retrasos de implementación
- ☐ Moderado: habrá mejora pero los datos seguirán siendo fragmentarios
- ☐ Bajo: el CRA no cambiará sustancialmente la situación práctica
- ☐ No conozco el Cyber Resilience Act o sus implicaciones en gestión de vulnerabilidades

P4.6 [Escala Likert 1-5] — Valore el nivel de integración actual entre su plataforma de gestión de vulnerabilidades y sus fuentes de threat intelligence:

Dimensión	1 (Nulo)	2 (Inicial)	3 (Parcial)	4 (Avanzado)	5 (Pleno)
Actualización automática de Exploit Maturity	☐	☐	☐	☐	☐
Correlación CVE-IOC-IOA en tiempo real	☐	☐	☐	☐	☐
Alertas automáticas cuando un CVE pasa a "Attacked"	☐	☐	☐	☐	☐
Integración con feeds EUVD / INCIBE-CERT / CCN-CERT	☐	☐	☐	☐	☐

SECCIÓN 5 — MÉTRICAS ENVIRONMENTAL: EL CONTEXTO QUE CALIBRA

Porque una vulnerabilidad crítica en un sistema desconectado es una anécdota. La misma en la historia clínica de urgencias es una catástrofe. El contexto lo es todo.

P5.1 — ¿Aplica su organización métricas Environmental (Modified Base Metrics + Security Requirements) al calcular puntuaciones CVSS? [Única]

- ☐ Sí, de forma sistemática para todos los sistemas del inventario
- ☐ Sí, pero solo para sistemas críticos (ENS Alto o equivalente)
- ☐ Esporádicamente, para casos especialmente relevantes
- ☐ No, utilizamos exclusivamente el CVSS-B o CVSS-BT sin ajuste ambiental
- ☐ No disponemos de la información de activos necesaria para calcular métricas ambientales

P5.2 — ¿Dispone su organización de un inventario de activos (CMDB o equivalente) suficientemente actualizado para calcular métricas ambientales CVSS con precisión? [Única]

- ☐ Sí, disponemos de una CMDB actualizada en tiempo real o casi real
- ☐ Sí, pero con actualizaciones periódicas (mensual/trimestral) que pueden generar desviaciones
- ☐ Disponemos de un inventario parcial que cubre los sistemas más críticos
- ☐ El inventario existe pero está desactualizado de forma significativa
- ☐ No disponemos de un inventario de activos formal
- ☐ Estamos en proceso de construir/actualizar el inventario

P5.3 — ¿Cómo establece los valores de Confidentiality/Integrity/Availability Requirements (CR/IR/AR) para sus sistemas? [Única]

- ☐ Los alineamos directamente con la categorización ENS (ALTO→High, MEDIO→Medium, BAJO→Low)
- ☐ Los determinamos mediante análisis de impacto de negocio (BIA) formal
- ☐ Los establecemos por criterio técnico del equipo de seguridad, caso a caso
- ☐ Usamos el valor por defecto (Not Defined) porque no hemos realizado esta clasificación
- ☐ No aplicamos métricas Environmental y por tanto no establecemos estos valores
- ☐ Otro (especifique): _____

P5.4 — Indique qué controles de seguridad existentes utiliza para ajustar las métricas Modified Base en sus evaluaciones CVSS [Múltiple]:

- ☐ Segmentación de red / microsegmentación (ajuste de MAV)
- ☐ Sistemas de detección/prevenición de intrusos (IDS/IPS) con firmas validadas (ajuste de MAC)
- ☐ Control de acceso privilegiado / PAM (ajuste de MPR)
- ☐ Gestión de dispositivos / MDM (ajuste de MUI)
- ☐ Cifrado de datos en reposo y tránsito (ajuste de MVC)
- ☐ Políticas de segmentación de aplicaciones / WAF (ajuste de MSC/MSI)
- ☐ Sistemas de backup y recuperación (ajuste de MVA)
- ☐ No realizamos ajustes con controles existentes; usamos el CVSS-B sin modificar
- ☐ No tenemos un proceso formal para traducir controles en ajustes de métricas

P5.5 — Cuando un sistema de categoría ENS ALTO presenta una vulnerabilidad con CVSS Base Score elevado, ¿cuál es el proceso de respuesta en su organización? [Única]

- ☐ Remediación inmediata ($\leq 24h$) mediante proceso de emergencia con aprobación directiva
- ☐ Remediación urgente ($\leq 72h$) con escalado al CISO y notificación al CCN-CERT si procede
- ☐ Remediación prioritaria en el próximo ciclo de parcheo planificado (≤ 7 días)
- ☐ Remediación en el ciclo de parcheo estándar (mensual)
- ☐ La categoría ENS no afecta directamente a los plazos de remediación
- ☐ No tenemos un proceso de respuesta diferenciado por categoría de sistema

P5.6 [Escala 1-5] — Valore la madurez de su organización en la aplicación de métricas Environmental:

Dimensión	1 (Inmaduro)	2 (Inicial)	3 (Definido)	4 (Gestionado)	5 (Optimizado)
Alineación CR/IR/AR con categorización ENS	☐	☐	☐	☐	☐
Traducción de controles existentes en métricas Modified	☐	☐	☐	☐	☐
Documentación formal del vector CVSS-BE para sistemas críticos	☐	☐	☐	☐	☐
Revisión periódica de métricas ambientales ante cambios de entorno	☐	☐	☐	☐	☐

SECCIÓN 6 — MÉTRICAS SUPPLEMENTAL: SEGURIDAD FÍSICA, RESILIENCIA Y AUTOMATIZACIÓN

Las vulnerabilidades que pueden matar la luz o parar los trenes merecen un indicador propio. Por fin lo tienen.

P6.1 — ¿Conoce las métricas Supplemental introducidas en CVSS 4.0? [Múltiple — marque las que conoce]

- ☐ Safety (S): indica si la explotación podría causar daño físico a personas
- ☐ Automatability (AU): indica si el ataque puede automatizarse (wormable)
- ☐ Recovery (R): evalúa la capacidad del sistema de recuperarse automáticamente
- ☐ Value Density (VD): indica si el sistema concentra recursos de alto valor para el atacante
- ☐ Vulnerability Response Effort (VRE): estima el esfuerzo de respuesta al proveedor
- ☐ Provider Urgency (U): canal de urgencia declarado por el fabricante
- ☐ Conozco su existencia pero no cada métrica individualmente
- ☐ No conocía las métricas Supplemental de CVSS 4.0

P6.2 — ¿Incorpora su organización la métrica Safety en la evaluación de vulnerabilidades de sistemas con potencial impacto físico (infraestructuras críticas, hospitales, industria, transporte)? [Única]

- ☐ Sí, la usamos sistemáticamente en todos los sistemas OT/ICS y dispositivos médicos
- ☐ La usamos de forma selectiva para los activos más críticos con impacto físico
- ☐ No la usamos porque no operamos este tipo de infraestructuras
- ☐ Sabemos que deberíamos usarla pero aún no la hemos implementado
- ☐ No conocía esta métrica antes de esta pregunta

P6.3 — En relación con la métrica Automatability (AU), ¿dispone de mecanismos para detectar cuando una vulnerabilidad es wormable (susceptible de propagación automatizada)? [Única]

- ☐ Sí, monitorizamos activamente fuentes de inteligencia que indican si una CVE es wormable
- ☐ Recibimos alertas de INCIBE-CERT o CCN-CERT cuando se detecta explotación masiva automatizada
- ☐ No tenemos mecanismos específicos para detectar la automatizabilidad de un ataque
- ☐ Confiamos en los parches automáticos y no diferenciamos entre vectores wormable y no wormable
- ☐ No conocía esta dimensión de evaluación de vulnerabilidades

P6.4 — Valore la importancia que su organización concede a cada métrica Supplemental en la toma de decisiones de remediación:

Métrica Supplemental	Sin importancia	Poca importancia	Importancia media	Alta importancia	Crítica
Safety (daño físico)	☐	☐	☐	☐	☐
Automatabilit y (wormable)	☐	☐	☐	☐	☐
Recovery (capacidad recuperación)	☐	☐	☐	☐	☐
Value Density (concentración de valor)	☐	☐	☐	☐	☐
Provider Urgency (urgencia fabricante)	☐	☐	☐	☐	☐

P6.5 [Abierta] — Describa un escenario real (anonimizado si es necesario) en el que una de las métricas Supplemental (Safety, Automatability, Recovery) habría cambiado radicalmente la decisión de priorización de una vulnerabilidad en su organización:

(Campo de texto libre — máx. 500 palabras. Las historias reales son los mejores datos.)

SECCIÓN 7 — INTEGRACIÓN CON MARCOS NORMATIVOS

La ciberseguridad regulada es la que llega a las reuniones de consejo. La no regulada espera en la cola.

P7.1 — ¿Está su organización sujeta a la Directiva NIS2 (Directiva UE 2022/2555)? [Única]

- ☐ Sí, como entidad esencial (sectores de alta criticidad: energía, transporte, banca, salud, agua, infraestructura digital)
- ☐ Sí, como entidad importante (sectores de criticidad media: servicios postales, residuos, fabricación, etc.)
- ☐ No estamos directamente sujetos, pero nuestros clientes/proveedores sí y afecta a nuestra cadena de suministro
- ☐ Estamos analizando si somos entidad esencial o importante
- ☐ No estamos sujetos a NIS2

P7.2 — ¿Cómo integra CVSS 4.0 en su proceso de notificación de incidentes bajo NIS2? [Única]

- ☐ La puntuación CVSS-BTE forma parte del protocolo de notificación en 24h para determinar si se supera el umbral de "incidente significativo"
- ☐ Usamos CVSS como referencia de severidad en la notificación pero sin un protocolo formalizado
- ☐ La notificación NIS2 no está directamente vinculada a nuestro proceso CVSS
- ☐ No hemos desarrollado aún el protocolo de notificación NIS2
- ☐ No aplica (no sujetos a NIS2)

P7.3 — Para las organizaciones sujetas a DORA (sector financiero): ¿qué papel juega CVSS en la evaluación de riesgos TIC exigida por el Reglamento? [Única]

- ☐ CVSS es la métrica principal de severidad técnica en nuestra gestión de vulnerabilidades TIC bajo DORA
- ☐ Usamos CVSS como uno de varios inputs (junto con EPSS, threat intel, impacto de negocio)
- ☐ No hemos establecido formalmente el rol de CVSS en el marco DORA
- ☐ No estamos sujetos a DORA
- ☐ Usamos metodologías propias del sector financiero distintas de CVSS

P7.4 — ¿Conoce las obligaciones del Cyber Resilience Act (CRA) en materia de notificación de vulnerabilidades explotadas activamente? [Única]

- ☐ Sí, conocemos en detalle las obligaciones de notificación a ENISA en 24h y el rol de la EUVD
- ☐ Conocemos el CRA pero no en detalle respecto a gestión de vulnerabilidades
- ☐ Estamos en proceso de análisis de impacto del CRA en nuestra organización
- ☐ No conocemos el Cyber Resilience Act

P7.5 — ¿Qué sistemas de puntuación o priorización de vulnerabilidades utiliza su organización actualmente? [Múltiple]

- ☐ CVSS (Common Vulnerability Scoring System — FIRST)
- ☐ EPSS (Exploit Prediction Scoring System)
- ☐ SSSVC (Stakeholder-Specific Vulnerability Categorization — CISA/SEI Carnegie Mellon)
- ☐ KEV (Known Exploited Vulnerabilities Catalog — CISA)
- ☐ EUVD (European Union Vulnerability Database — ENISA)
- ☐ DREAD (metodología de puntuación cualitativa)
- ☐ Sistema de scoring propio o adaptado
- ☐ Sistema del MSSP o proveedor de seguridad gestionada
- ☐ No utilizamos ningún sistema formal de puntuación

P7.6 [Escala 1-5] — Valore el nivel de alineación entre su gestión de vulnerabilidades CVSS y los siguientes marcos normativos:

Marco normativo	1 (Sin alineación)	2 (Mínima)	3 (Parcial)	4 (Sustancial)	5 (Plena)	N/A
ENS (Esquema Nacional de Seguridad)	☐	☐	☐	☐	☐	☐
NIS2 (Directiva UE 2022/2555)	☐	☐	☐	☐	☐	☐
DORA (Reglament o UE 2022/2554)	☐	☐	☐	☐	☐	☐
CRA (Reglament o UE 2024/2847)	☐	☐	☐	☐	☐	☐
ISO 27001:2022	☐	☐	☐	☐	☐	☐
NIST CSF 2.0	☐	☐	☐	☐	☐	☐

SECCIÓN 8 — INFRAESTRUCTURA TECNOLÓGICA Y HERRAMIENTAS

Las mejores metodologías mueren en manos de las peores herramientas. O sobreviven gracias a las mejores.

P8.1 — ¿Qué tipo de herramientas utiliza para la gestión de vulnerabilidades? [Múltiple]

- ☐ Escáner de vulnerabilidades de red (Nessus, Qualys, OpenVAS, Nexpose, Rapid7...)
- ☐ Plataforma de gestión de vulnerabilidades con priorización (Vulcan, Nucleus, Kenna, Tenable.io...)
- ☐ Sistema SIEM con correlación de vulnerabilidades e incidentes
- ☐ Plataforma de threat intelligence (MISP, OpenCTI, feeds comerciales...)
- ☐ SOAR con flujos automatizados de respuesta a vulnerabilidades
- ☐ Plataforma de gestión de activos / CMDB integrada con datos de vulnerabilidades
- ☐ Herramientas CCN (ARES, CARMEN, GLORIA, MARTA...)
- ☐ Herramientas INCIBE-CERT (INCIBE-Alerta, CAIF...)
- ☐ Herramienta propia o desarrollada a medida
- ☐ Hojas de cálculo / gestión manual
- ☐ No disponemos de herramientas específicas de gestión de vulnerabilidades

P8.2 — ¿Sus herramientas actuales de gestión de vulnerabilidades soportan CVSS 4.0 de forma nativa? **[Única]**

- ☐ Sí, soportan CVSS 4.0 con cálculo de vectores CVSS-B, CVSS-BT, CVSS-BE y CVSS-BTE
- ☐ Sí, pero solo muestran el score CVSS 4.0 sin facilitar el cálculo de métricas Threat/Environmental
- ☐ Parcialmente: algunas herramientas sí y otras no
- ☐ No, nuestras herramientas actuales solo soportan CVSS 3.x
- ☐ No lo sabemos con certeza

P8.3 — ¿Utiliza o evalúa el uso de Inteligencia Artificial o LLMs para automatizar o asistir la puntuación CVSS? [Única]

- ☐ Sí, disponemos de herramientas de IA que asignan o proponen puntuaciones CVSS de forma automática
- ☐ Estamos evaluando o pilotando herramientas de puntuación automatizada con IA
- ☐ Conocemos el potencial de los LLMs para este fin pero no lo hemos implementado
- ☐ No utilizamos ni evaluamos IA para la puntuación CVSS
- ☐ No conocía que los LLMs pueden asistir en la puntuación automática de vulnerabilidades

P8.4 — ¿Cuál es el tiempo medio transcurrido entre la publicación pública de un CVE y la asignación de puntuación CVSS en su organización? [Única]

- ☐ Menos de 24 horas (proceso automatizado con feeds en tiempo real)
- ☐ 1-7 días
- ☐ 1-4 semanas
- ☐ Más de 4 semanas (o alineado con ciclos de parcheo)
- ☐ No medimos este indicador
- ☐ Adoptamos directamente la puntuación del NVD/INCIBE sin proceso propio

P8.5 — ¿Qué porcentaje aproximado del parque tecnológico de su organización tiene cobertura activa de escaneo de vulnerabilidades? [Única]

- ☐ Más del 95%
- ☐ 80-95%
- ☐ 60-80%
- ☐ 40-60%
- ☐ Menos del 40%
- ☐ No lo sabemos con precisión

P8.6 — ¿Dispone de integración entre su plataforma de gestión de vulnerabilidades y su sistema de gestión de incidentes (ticketing/ITSM)? [Única]

- ☐ Sí, integración bidireccional y automatizada
- ☐ Sí, integración unidireccional (las vulnerabilidades generan tickets automáticamente)
- ☐ Integración manual: los equipos trasladan manualmente los datos entre sistemas
- ☐ No existe integración entre ambos sistemas
- ☐ No disponemos de sistema ITSM formal

SECCIÓN 9 — GOBIERNO, CULTURA Y CAPACITACIÓN

Un CISO que no puede explicar CVSS al consejo de administración tiene un problema de comunicación. Un consejo que no pregunta tiene un problema de gobernanza.

P9.1 — ¿Se reportan métricas CVSS al nivel directivo/consejo de administración de forma regular? [Única]

- ☐ Sí, incluimos métricas CVSS (distribución de severidad, evolución del backlog, cobertura de remediación) en informes periódicos a dirección
- ☐ Reportamos incidentes de seguridad pero no específicamente métricas CVSS
- ☐ La seguridad se reporta a dirección de forma muy general, sin métricas técnicas específicas
- ☐ No se reporta información de ciberseguridad al nivel directivo de forma regular
- ☐ El comité de ciberseguridad existe pero no tiene representación directiva

P9.2 — ¿Dispone su organización de un proceso formal de gestión de vulnerabilidades (VMP — Vulnerability Management Program) documentado? [Única]

- ☐ Sí, documentado, aprobado, revisado periódicamente y auditado externamente
- ☐ Sí, documentado y aprobado, pero sin auditoría externa
- ☐ Existe un proceso informal, pero no está completamente documentado
- ☐ No disponemos de un proceso formal de gestión de vulnerabilidades
- ☐ Estamos en proceso de documentarlo

P9.3 — ¿Qué porcentaje estimado del personal de seguridad de su organización ha recibido formación específica en CVSS 4.0? [Única]

- ☐ Más del 80%
- ☐ 50–80%
- ☐ 20–50%
- ☐ Menos del 20%
- ☐ Ninguno (no hemos impartido formación específica en CVSS 4.0)
- ☐ No aplicamos CVSS y por tanto no existe demanda de formación en él

P9.4 — ¿Existe en su organización un proceso formal de identificación y gestión de vulnerabilidades en la cadena de suministro (proveedores, terceros, software open source)? [Única]

- ☐ Sí, disponemos de un programa de gestión de riesgo de terceros con evaluación de vulnerabilidades
- ☐ Sí, incluimos cláusulas contractuales de gestión de vulnerabilidades para proveedores críticos
- ☐ Lo hacemos de forma ad hoc para los proveedores más críticos
- ☐ No, la gestión de vulnerabilidades se limita a nuestro perímetro interno
- ☐ Estamos desarrollando un programa de gestión de riesgo de terceros

P9.5 — ¿Cuál es el principal obstáculo organizacional (no tecnológico) para mejorar la gestión de vulnerabilidades con CVSS? [Única]

- ☐ Falta de presupuesto asignado específicamente a gestión de vulnerabilidades
- ☐ Escasez de personal cualificado (el mercado laboral de ciberseguridad en España tiene una brecha estimada de >30.000 profesionales)
- ☐ Resistencia cultural: los propietarios de sistemas no priorizan el parcheo frente a la disponibilidad
- ☐ Complejidad de los entornos legacy y tecnología no actualizable
- ☐ Ausencia de apoyo directivo para invertir en mejoras del proceso
- ☐ Falta de tiempo: la operación diaria consume todos los recursos disponibles
- ☐ No percibimos obstáculos organizacionales significativos
- ☐ Otro (especifique): ____

P9.6 [Escala 1-5] — Valore la madurez de su organización en las siguientes dimensiones de gobierno de vulnerabilidades:

Dimensión	1 (Inexistente)	2 (Inicial)	3 (Definido)	4 (Gestionado)	5 (Optimizado)
Política formal de gestión de vulnerabilidades	☐	☐	☐	☐	☐
SLAs de remediación por nivel de severidad CVSS	☐	☐	☐	☐	☐
KPIs de vulnerabilidades reportados a dirección	☐	☐	☐	☐	☐
Programa de formación continua en CVSS y vulnerabilidades	☐	☐	☐	☐	☐
Gestión de vulnerabilidades en cadena de suministro	☐	☐	☐	☐	☐
Ejercicios de tabletop con escenarios de vulnerabilidades críticas	☐	☐	☐	☐	☐

SECCIÓN 10 — PERSPECTIVA ESTRATÉGICA Y TENDENCIAS EMERGENTES

El futuro de CVSS está siendo escrito ahora mismo en laboratorios de investigación, reuniones del FIRST SIG y salas de crisis de los SOC. Conviene tener opinión.

P10.1 — ¿Cuál cree que es la mayor limitación sistémica del CVSS como herramienta de gestión de riesgo de vulnerabilidades? [Única]

- ☐ Mide severidad técnica, no riesgo organizacional real (el más citado en la literatura)
- ☐ La cobertura de CVEs con puntuación v4 sigue siendo marginal (~2,4% del total)
- ☐ La complejidad de las métricas Environmental/Supplemental desincentiva su uso correcto
- ☐ La divergencia entre versiones (v3.1 vs v4.0) genera inconsistencias en la comparación temporal
- ☐ La dependencia de NVD (con su backlog de >26.000 CVEs sin analizar) hace el sistema poco fiable
- ☐ La ausencia de incentivos para que los fabricantes actualicen puntuaciones CVSS de forma regular
- ☐ CVSS es fundamentalmente correcto; el problema está en la implementación, no en el estándar
- ☐ Otro (especifique): _____

P10.2 — En su opinión, ¿cuál debería ser la evolución de CVSS en los próximos 2-3 años? [Múltiple]

- ☐ Mayor integración nativa con fuentes de threat intelligence en tiempo real (EPSS, KEV, EUVD)
- ☐ Automatización total de la puntuación Base mediante LLMs validados con supervisión humana
- ☐ Perfiles sectoriales oficiales de métricas ambientales (sanidad, energía, administración pública...)
- ☐ Integración obligatoria en los procesos de notificación NIS2/CRA/DORA
- ☐ Convergencia con SSVC u otros sistemas alternativos en un meta-framework unificado
- ☐ Simplificación del estándar para hacerlo más accesible a organizaciones con menos recursos
- ☐ Mayor peso a las métricas Supplemental en la puntuación final (actualmente sin efecto numérico)
- ☐ Otro (especifique): _____

P10.3 — ¿Considera que la Red Nacional de SOC (RNS) del CCN-CERT mejora efectivamente la disponibilidad de métricas Threat para las organizaciones de la Administración Pública española? [Única]

- ☐ Sí, es una infraestructura de inteligencia compartida que aporta valor real en la actualización de métricas Threat
- ☐ Tiene potencial pero la compartición de inteligencia efectiva es aún limitada
- ☐ No tenemos acceso o no somos miembros de la RNS
- ☐ No conozco la Red Nacional de SOC del CCN-CERT
- ☐ Es una estructura burocrática que añade poco valor operacional

P10.4 — Valore el impacto de la EUVD (European Union Vulnerability Database, ENISA 2025) en la soberanía digital europea respecto a la gestión de vulnerabilidades: [Única]

- ☐ Transformador: reduce la dependencia del NVD/NIST y establece una cadena de autoridad europea
- ☐ Relevante pero insuficiente: necesita más masa crítica de CNAs europeos para ser realmente alternativa
- ☐ Complementario: la EUVD es un buen complemento pero no un sustituto del NVD
- ☐ Marginal: el ecosistema global de vulnerabilidades seguirá dominado por estándares americanos
- ☐ No conozco la EUVD con suficiente detalle para valorarla

P10.5 [Abierta] — ¿Qué propuesta concreta realizaría a la Administración Pública española (CCN, INCIBE, CNPIC) para mejorar la aplicación territorial y sectorial de CVSS 4.0 en España?

(Campo de texto libre — máx. 600 palabras. Las mejores políticas se construyen desde la práctica.)

P10.6 [Abierta] — Si pudiera cambiar un solo aspecto del estándar CVSS (cualquier versión), ¿cuál sería y por qué?

(Campo de texto libre — máx. 300 palabras.)

SECCIÓN 11 — INDICADORES DE MADUREZ GLOBAL (IGM)

La autopercepción tiene sus límites, pero también tiene su valor. Especialmente cuando es honesta.

P11.1 — Valore globalmente el nivel de madurez de su organización en gestión de vulnerabilidades con CVSS en una escala 1-10:

1	2	3	4	5	6	7	8	9	10	
Inexistente						Básico			Avanzado	Referencia

Selección: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5 ☐ 6 ☐ 7 ☐ 8 ☐ 9 ☐ 10

P11.2 — En una escala 1-10, ¿dónde situaría a la media del sector público español en gestión de vulnerabilidades con CVSS?

Selección: ☐ 1 ☐ 2 ☐ 3 ☐ 4 ☐ 5 ☐ 6 ☐ 7 ☐ 8 ☐ 9 ☐ 10

P11.3 — ¿Cuál es la principal mejora que su organización planea implementar en gestión de vulnerabilidades en los próximos 12 meses? [Única]

- ☐ Migrar a CVSS 4.0 como versión de referencia
- ☐ Implementar métricas Threat con integración de threat intelligence en tiempo real
- ☐ Desarrollar perfiles de métricas Environmental alineados con ENS
- ☐ Actualizar el inventario de activos (CMDB) para habilitar análisis contextual
- ☐ Implementar automatización de puntuación CVSS con IA/LLM
- ☐ Integrar CVSS con el proceso de notificación NIS2/DORA/CRA
- ☐ Desarrollar formación específica en CVSS 4.0 para el equipo de seguridad
- ☐ No tenemos planes de mejora específicos en este ámbito para los próximos 12 meses
- ☐ Otro (especifique): _____

AGRADECIMIENTO FINAL

Gracias por haber llegado hasta aquí. La ironía implícita al inicio de muchas preguntas no era descortesía, sino reconocimiento compartido de que la brecha entre norma y práctica es, en sí misma, el objeto de estudio. Su aportación contribuye a medirla con rigor y a reducirla con propósito.

Kit de Encuesta CVSS 4.0 · España 2025–2026

Versión 1.0 · Abril 2026

Elaborado por el Consorcio Internacional de Investigación en Ciberseguridad y Resiliencia Digital